

3.5 Task 5: Launching a Man-In-The-Middle Attack

In this task, we will show how PKI can defeat Man-In-The-Middle (MITM) attacks. Figure 1 depicts how MITM attacks work. Assume Alice wants to visit `example.com` via the HTTPS protocol. She needs to get the public key from the `example.com` server; Alice will generate a secret, and encrypt the secret using the server's public key, and send it to the server. If an attacker can intercept the communication between Alice and the server, the attacker can replace the server's public key with its own public key. Therefore, Alice's secret is actually encrypted with the attacker's public key, so the attacker will be able to read the secret. The attacker can forward the secret to the server using the server's public key. The secret is used to encrypt the communication between Alice and the server, so the attacker can decrypt the encrypted communication.

The goal of this task is to help students understand how PKI can defeat such MITM attacks. In the task, we will emulate an MITM attack, and see how exactly PKI can defeat it. We will select a target website first. In this document, we use `www.example.com` as the target website, but in the task, to make it more meaningful, students should pick a popular website, such as a banking site and social network site.

Step 1: Setting up the malicious website. In Task 4, we have already set up an HTTPS website. We will use the same Apache server to impersonate `www.example.com` (or the site chosen by students). To achieve that, we will follow the instruction in Task 4 to add a `VirtualHost` entry to Apache's SSL configuration file: the `ServerName` should be `www.example.com`, but the rest of the configuration can be the same as that used in Task 4. Obviously, in the real world, you won't be able to get a valid certificate for `www.example.com`, so we will use the same certificate that we used for our own server.

Our goal is the following: when a user tries to visit `www.example.com`, we are going to get the user to land in our server, which hosts a fake website for `www.example.com`. If this were a social network website, The fake site can display a login page similar to the one in the target website. If users cannot tell the difference, they may type their account credentials in the fake webpage, essentially disclosing the credentials to the attacker.

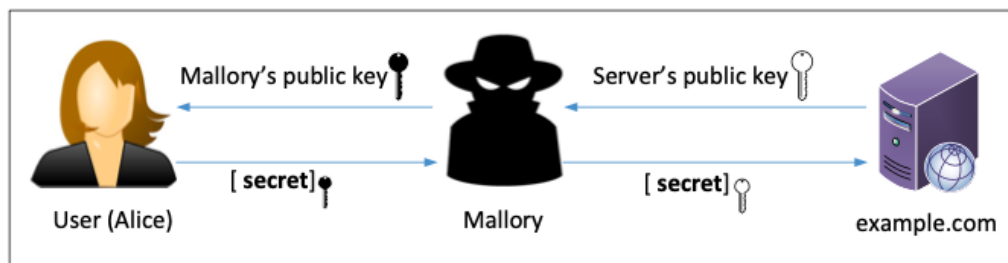


Figure 1: A Man-In-The-Middle (MITM) attack

Step 2: Becoming the man in the middle There are several ways to get the user's HTTPS request to land in our web server. One way is to attack the routing, so the user's HTTPS request is routed to our web server. Another way is to attack DNS, so when the victim's machine tries to find out the IP address of the target web server, it gets the IP address of our web server. In this task, we simulate the attack-DNS approach. Instead of launching an actual DNS cache poisoning attack, we simply modify the victim's machine's `/etc/hosts` file to emulate the result of a DNS cache poisoning attack by mapping the hostname `www.example.com` to our malicious web server.

```
10.9.0.80 www.example.com
```

Step 3: Browse the target website. With everything set up, now visit the target real website, and see what your browser would say. Please explain what you have observed.

3.6 Task 6: Launching a Man-In-The-Middle Attack with a Compromised CA

In this task, we assume that the root CA created in Task 1 is compromised by an attacker, and its private key is stolen. Therefore, the attacker can generate any arbitrary certificate using this CA's private key. In this task, we will see the consequence of such a compromise.

Please design an experiment to show that the attacker can successfully launch MITM attacks on any HTTPS website. You can use the same setting created in Task 5, but this time, you need to demonstrate that the MITM attack is successful, i.e., the browser will not raise any suspicion when the victim tries to visit a website but land in the MITM attacker's fake website.